

#07 · 個資遮蔽

[修復] 技術代號 O-PO-1 · 約 0.5-1 天

一句話：個資洩漏在日誌

為什麼要修

PII 遮蔽函式（把 email、API key 等換成 [REDACTED]）已寫好，但只用在記憶系統。

現在怎樣

shared/orb-memory.ts 已有 containsSensitiveText / sanitizeMemoryText / sanitizeMemoryMetadata。但 server/_core/logger.ts:write() 與 server/services/langsmithTracer.ts:summarize() 只部分覆蓋。

問題在哪

登入紀錄、錯誤訊息、LangSmith trace 可能洩漏使用者 email / API key / 信用卡 / 身份證。

要改什麼

新增 server/_core/pii-redactor.ts 模組（補 email/phone/身份證 pattern），hook 到 logger 與 langsmithTracer 全部寫入路徑。

涉及檔案

server/_core/pii-redactor.ts（新增）

server/_core/logger.ts:write()（line 119-126，改用 redacted 序列化）

server/services/langsmithTracer.ts:summarize()（line 20-37，加強）

shared/orb-memory.ts（重用 sanitizeMemoryText / containsSensitiveText）

Claude Code 提示詞 (複製貼上)

把下面這段話完整複製，貼到 Claude Code (或 /claude 對話)。Claude Code 會依此完成此項修復。完成後跑下方驗證步驟確認。

請依照計畫附錄 A.7 實作 O-PO-1 PII 遮蔽：

1. 新增 server/_core/pii-redactor.ts，匯出三個函式：

```
```typescript
import { sanitizeMemoryText, containsSensitiveText } from "../../shared/orb-memory";

const EMAIL_RE = /\b[A-Z0-9._%+-]+@[A-Z0-9.-]+\.[A-Z]{2,}\b/gi;
const PHONE_RE = /\b\+?\d{1,3}[\s-]?(?\d{2,4})?[\s-]?\d{3,4}[\s-]?\d{3,4}\b/g;
const TWID_RE = /\b[A-Z][12]\d{8}\b/g;

export function redactForLogging(text: string): string {
 return sanitizeMemoryText(text)
 .replace(EMAIL_RE, "[EMAIL]")
 .replace(PHONE_RE, "[PHONE]")
 .replace(TWID_RE, "[TWID]");
}

export function redactLLMParams<T extends { messages?: { content: string }[] }>(params: T): T { ... }
export { containsSensitiveText };
```
```

2. 修改 server/_core/logger.ts:write() (line 119-126)，新增 safeSerializeWithRedaction(meta) 函式：先 JSON.stringify(meta) → 對結果字串跑 redactForLogging → 回傳。把原本 safeSerialize 換成 safeSerializeWithRedaction。

3. 修改 server/services/langsmithTracer.ts:summarize() (line 20-37)：把現有 partial 過濾改成統一呼叫 redactForLogging。對 input / output 兩個欄位都處理。

4. 寫一條 vitest 測試：log 一條包含「我的 email 是 abc@example.com、API key 是 sk-xxx、身份證 A123456789」→ logger 輸出應為 [EMAIL] + [REDACTED] + [TWID]。LangSmith trace 同樣應遮蔽。orbLongTermMemories.content 既有 sanitize 路徑不應變更（雙保險）。

不要做的事：不要動 shared/orb-memory.ts 既有 sanitize 函式。不要做 AI 模型化偵測（屬未來擴張）。不要把 redaction 套到 user-facing UI（會破壞 prompt 顯示）。

如何驗證做完了

跑一條包含 email / API key 的 prompt → grep server log 確認無明文 email ; LangSmith UI 看 trace 內 content 也已遮蔽。

預估耗時

0.5-1 天